Security & Privacy (HIPAA) Risk Assessment – Mode: Databricks-to-Open

Document control	
Document ID	RA-TRB-2026-007
Document type	Security & Privacy Risk Assessment
Date	2026-08-11
Status	Approved
Review IDs	TRB-2026-007
Feature keys	Mode: Databricks-to-Open (bearer/OIDC)@Sharing & Collaboration
Classification	Internal – Synthetic Sample

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

Feature Name: Mode: Databricks-to-Open (Data Sharing with Bearer Token / OIDC)
Review ID: TRB-2026-007
Assessment Date: August 11, 2026
Assessed By: Privacy Officer
Overall Risk Level: Moderate (mitigated to Low via conditions)
PHI-Eligible? Conditional Yes (with BAA, token controls, and monitoring)

---

1. Executive Summary

Mode enables Databricks tables to be shared with external recipients (non-Databricks customers) via bearer token or OIDC authentication. Recipients access data via a web UI or API. Acme Health Plan proposes sharing member claims data with research organizations under Data Use Agreements (DUAs) and Business Associate Agreements (BAAs).

Risk: Bearer tokens can be compromised, exfiltrated, or shared. External recipients' security posture is unknown.

Mitigation: Short token lifetime (≤30 days), IP allowlists, audit logging, BAA requirement, anomaly detection.

With conditions, risk acceptable for PHI sharing with vetted partners.

---

2. Risk Assessment Context

2.1 System Boundaries

In scope:
- Mode bearer token generation and validation
- External recipient's access to shared Databricks tables
- Query execution and result delivery to external recipient

Out of scope:
- External recipient's local security (data handling post-download)
- Mode infrastructure security (inherited Databricks/AWS controls)

2.2 Data Classification

Data to Be Shared: Member claims (medical claims, pharmacy, mental health), member demographics (age, region, diagnosis groupings—NOT names or SSN)
Sensitivity: PHI (HIPAA-regulated); shared only under BAA with recipient
Volume: Estimated 10M annual claims records for research partners
Recipients (Proposed): 2–3 healthcare research organizations (universities, biotech firms)

---

3. Threat & Vulnerability Analysis

3.1 Threat Sources

Threat Source	Likeli-hood	Impact	Notes
Bearer token compromise	Medium	Critical	If token exfiltrated, attacker has query access to shared table
Bearer token sharing (intentional)	Medium	Critical	External recipient shares token with unauthorized third party
Weak recipient security posture	Medium	High	Recipient's network/systems breached; attacker uses shared token

Threat Source	Likeli-hood	Impact	Notes
Query-pattern reconnaissance	Low	Medium	Attacker runs queries to profile members (e.g., rare disease count)
Token/credential reuse	Low	Medium	Recipient reuses token across insecure networks/devices
Insider threat (Acme employee)	Low	Critical	Employee shares token with unauthorized person

3.2 Vulnerability Assessment

Administrative Safeguards (45 CFR § 164.308)

Control	Re-quired?	Imple-men-ted?	Evidence	Gap
Business Associate Agreement	Yes	[ ]	BAA template exists; must be signed before token issued	**COND-007-1: BAA required; Legal confirms before provisioning**
Workforce Authorization	Yes	[x]	Only Data Governance team can request Mode shares	None
Termination Procedures	Yes	[~]	No formal offboarding for external recipients	**Gap: If recipient access needs to end, token revocation must be immediate**
Audit Controls	Yes	[~]	Query logs exist; but no anomaly detection	**COND-007-3: Require anomaly monitoring**

Technical Safeguards (45 CFR § 164.312)

Control	Required?	Imple-men-ted?	Evidence	Gap
Access Control (Authentication)	Yes	[x]		

Control	Required?	Imple-men-ted?	Evidence	Gap
			Bearer token or OIDC; single-use tokens	**Gap: Bearer tokens are stateless; no way to verify intent**
Access Control (Authorization)	Yes	[x]	Shared table permissions limited; recipient can't access other tables	None
Audit Controls & Logging	Yes	[x]	Mode logs query, IP, timestamp, result size	**COND-007-3: Require access to logs; 180-day retention**
Transmission Security	Yes	[x]	TLS 1.2+ enforced for Mode connections	None
Encryption (At Rest)	Addressable	[x]	Shared data encrypted via AWS KMS	None

Physical Safeguards (45 CFR § 164.314)

Control	Re-quired?	Imple-mented?	Evidence	Gap
Facility Access	N/A	-	Recipient's facilities out of scope (covered by recipient's security)	None
Workstation Security	N/A	-	Recipient's workstations out of scope	None

4. Risk Analysis

4.1 Identified Risks

#	Threat	Vulnerability	Likelihood	Impact	Risk Score	Mitigation
1	Bearer token exfiltrated (intercepted in transit / stolen from recipient's system)	Tokens are bearer credentials; no per-request signing or MFA	Medium	Critical	12	**COND-007-2:** Token lifetime ≤30 days; IP allowlist if recipient network known; rotate token quarterly
2	Bearer token shared with unauthorized third party	Mode doesn't prevent token sharing (stateless auth)	Medium	Critical	12	**COND-007-1 & 3:** BAA prohibits sharing; audit logs detect anomalies (e.g., queries from new IP); escalate
3	Recipient's system breached; attacker uses token for reconnaissance	Recipient may have weak security controls	Medium	High	9	**COND-007-1:** BAA includes security requirement (TLS, MFA, access logging at recipient). Acme requests evidence.
4	Query-pattern reconnaissance (e.g., repeated queries for rare disease counts)	Attacker learns member cohort sizes, infers identities	Low	Medium	5	**COND-007-3:** TRB flags queries with >10 results per 24hr; anomaly escalation threshold
5	Token accidental leak (e.g., logged in debug mode, pasted in chat)	No preventive control in Mode itself	Low	Critical	5	**COND-007-1:** Recipient training; BAA audit clauses

#	Threat	Vulnerability	Likelihood	Impact	Risk Score	Mitigation
6	Insider (Acme employee) intentionally shares token	Requires deliberate bypass	Low	Critical	5	Standard access control + audit; escalate to CISO if detected

4.2 Risk Mitigation (Conditions)

Condition ID	Mitigation	Effectiveness
COND-007-1	BAA signed before Mode token issued; BAA requires recipient to implement TLS, access logging, and not share token. Legal confirms BAA on file before provisioning.	High—legal obligation + verification
COND-007-2	Bearer token lifetime ≤30 days; quarterly rotation. IP allowlist configured if recipient network IP known. Test token with test query before handoff.	High—limits exposure window & restricts source IPs
COND-007-3	All Mode queries logged (recipient IP, query, result count, timestamp) to Databricks audit tables. Monthly anomaly review: >10 queries in 24hr, unusual IPs, abnormal result sizes flagged. 180-day retention.	Medium–High—enables detection & investigation

---

5. Residual Risk Statement

After conditions are met, residual risk is LOW.

- **Token Compromise:** Mitigated by short lifetime (30 days) + IP allowlist + monitoring. Residual: Token compromised, used within 30 days without anomaly detection (low likelihood).
- **Recipient Breach:** Mitigated by BAA requirement + audit logging. Residual: Recipient breached, attacker queries undetected for days (very low due to monthly monitoring).
- **Insider Threat:** Standard access controls. Residual: Rogue employee intentionally leaks token (baseline security risk).

Assumption: Acme Health Plan maintains monthly audit review discipline. If reviews skipped or under-resourced, anomalies may go undetected (risk increases to Medium).

---

6. Data Use Limits & Recipient Vetting

Recipient Security Checklist (to be completed before token issuance):
- [ ] Recipient organization has executed BAA with Acme Health Plan
- [ ] Recipient has SOC 2 Type II certification (or equivalent security audit)
- [ ] Recipient's security officer confirms TLS 1.2+, access logging, MFA on admin accounts
- [ ] Recipient commits to no third-party sharing of token / data
- [ ] Recipient provides incident contact (24/7 escalation for data breaches)

---

7. Compliance & Audit Notes

Regulatory Framework:
- HIPAA Privacy Rule § 164.504(e) (Business Associate Agreements): BAA mandatory before sharing PHI with external recipients
- HIPAA Security Rule § 164.312 (Technical Safeguards): Access controls, audit logging
- 45 CFR § 164.504(e)(2)(ii)(H) (Termination Clauses): Upon termination, recipient must return/destroy PHI

Audit Trail Retention:
- Mode query logs: 180 days (retained in Databricks audit tables)
- BAA documentation: 6 years (per HIPAA retention requirement)
- Anomaly detection reports: 1 year (per Acme policy)

---

8. Recommendation

✓ **RECOMMEND APPROVAL WITH CONDITIONS**

Decision: Mode is fit for PHI sharing with external recipients when conditions (COND-007-1 through COND-007-3) are met and verified.

Approval Authority: TRB Board (unanimous vote required for PHI)

Next Step: TRB to issue Conditional Approval Letter. Requestor to:
1. Obtain BAA signature from each recipient
2. Configure token lifetime & IP allowlist per COND-007-2
3. Verify audit logging per COND-007-3
4. Submit evidence to TRB lead for verification

Quarterly Re-audit: TRB will review Mode audit logs monthly and anomaly reports quarterly.

Assessment Completed By:
Privacy Officer
Signature: _____ Date: August 11, 2026

Reviewed By:
CISO
Signature: _____ Date: August 15, 2026

Classification: Internal – Synthetic Sample